

ISO/IEC 27001:2022

Controles 8.25, 8.28 y 8.29

Equipo 5 — IS-722 Calidad de Software

2026-I

Norma internacional para la gestión de seguridad de la información. Requisitos para proteger confidencialidad, integridad y disponibilidad.

Anexo A — Controles tecnológicos:

- 93 controles en 4 temas
- **A.8:** Controles tecnológicos (34)
- Enfocados en **8.25, 8.28 y 8.29**

SGSI

Sistema de Gestión de Seguridad de la
Información

8.25

Secure Development Life Cycle

Reglas para desarrollo seguro durante todo el ciclo de vida.

8.28

Secure Coding

Principios de codificación segura para reducir vulnerabilidades.

8.29

Security Testing

Pruebas de seguridad durante desarrollo y antes de producción.

Un **Secure SDLC** integra seguridad en cada fase. Concepto clave: **Shift Left**

mover seguridad hacia fases iniciales.

Modelo tradicional

Análisis → Diseño → Desarrollo → Testing →
Producción

Ahora revisemos seguridad''

SSDLC (Shift Left)

Seguridad desde **Requisitos**, no al final.

Fase 1: Requisitos

- Activos de información
- Clasificación de la información
- Requisitos CIA

Fase 2: Diseño Seguro

- Threat Modeling (STRIDE)
- Diagrama de Flujo de Datos
- Límites de confianza

Fase 3: Desarrollo → 8.28 Fase 4: Pruebas

→ 8.29 Fase 5: Despliegue

- Hardening, secretos, CI/CD

Fase 6: Mantenimiento

- Parches, monitoreo continuo

Amenaza	Significado	Pregunta
Spoofing	Suplantación	¿Quién es el usuario?
Tampering	Manipulación	¿Se alteran los datos?
Repudiation	Negación	¿Quién hizo qué?
Info Disclosure	Exposición	¿Se lee info confidencial?
DoS	Indisponibilidad	¿Se interrumpe el servicio?
Escalada	Privilegios	¿Se obtienen permisos extra?

1. Nunca confiar en la entrada Toda entrada es no confiable hasta que se valide.

2. Validar siempre Tipo, longitud, formato, rango.

3. Sanitizar Preparar datos para uso seguro.

4. Mínimo privilegio Solo los permisos necesarios.

5. Secretos Nunca hardcodear. Usar .env.

6. Errores seguros No exponer stack traces.

7. Dependencias Escanear, actualizar.

Vulnerabilidad	Nivel	Prevención
Injection	Crítica	Consultas parametrizadas
Broken Access Control	Crítica	Mínimo privilegio
Cryptographic Failures	Alta	bcrypt, JWT expiración
Security Misconfiguration	Alta	Hardening
Vulnerable Components	Alta	Escaneo dependencias

SAST — Análisis Estático

Analiza código sin ejecutarlo. Escáner busca patrones.

ESLint, Semgrep, SonarQube

DAST — Análisis Dinámico

Prueba app ejecutándose. Ataques simulados.

OWASP ZAP, Burp Suite

Code Review

Revisión humana. Errores de lógica.

Penetration Testing

Especialista compromete el sistema.

Criterios antes de producción:

- **0** vulnerabilidades críticas
- **0** vulnerabilidades altas
- Cobertura SAST $\geq 80\%$
- Dependencias sin CVEs críticos

Si no cumple, no se despliega.

Git Push → Build → Unit Tests → SAST → Dependency Scan → DAST → Security Gate
→ Staging → Production

Integra **8.25** (proceso), **8.28** (código) y **8.29** (validación).

Métrica	Fórmula	Objetivo
Densidad vuln.	$D_v = \frac{V}{\text{KLOC}}$	$D_v < 1$
Cobertura SAST	$C = \frac{A_{\text{esc}}}{A_{\text{tot}}} \times 100$	$C \geq 80\%$
Tiempo remediación	$T_{\text{rem}} = \frac{\sum \Delta t}{n}$	$T_{\text{rem}} \leq 7 \text{ días}$
Tasa aceptación	$R = \frac{P_{\text{apr}}}{P_{\text{tot}}} \times 100$	$R = 100\%$
Madurez SSDLC	$M = \frac{\sum P_i w_i}{\sum w_i}$	Nivel ≥ 2

Stack: React, Node.js, MongoDB, MinIO, Docker

Métricas:

- $D_v = 0.6$ (Bajo)
- $C_{\text{SAST}} = 88.9\%$
- $T_{\text{rem}} = 5$ días
- Madurez: Nivel 2

Hallazgos:

- JWT_SECRET hardcodeado
- Credenciales MinIO por defecto
- MongoDB puerto expuesto

Sin proceso formal, estos problemas pasan desapercibidos.

- Política de Secure SDLC
- Principios de codificación aprobados
- Revisiones de código
- Threat modeling
- Resultados SAST y DAST
- Pipeline CI/CD con Security Gate

Busca un proceso definido, aplicado y demostrable.

¿Preguntas?

Equipo 5 — IS-722 Calidad de Software